

INFORME DE AUDITORIA DE SEGURIDAD WEB v5.0

Análisis pasivo · No invasivo · 100% seguro para el sitio

Sitio web analizado

example.com

https://example.com

Fecha del análisis	17 de Mayo de 2026
Hora de generación	19:36
Tipo de análisis	Pasivo y no invasivo — sin modificaciones ni riesgo para el sitio
Módulos evaluados	11
Cumplimiento estándar	75% de las recomendaciones de seguridad
Calificación global	B (Buena) — 80 / 100 puntos
Auditor	Ignacio Nicolas Ledesma

Resumen Ejecutivo

El sitio web **example.com** presenta una **postura de seguridad aceptable**, con 1 problema(s) crítico(s) y 8 advertencia(s) que requieren atención.

1	8	15	13	B
Críticos	Advertencias	Correctos	Informativos	Nota 80/100

Resultados por Área Evaluada

ÁREA DE EVALUACIÓN	NOTA	PUNTAJE	ESTADO GENERAL
Puertos Expuestos, Banner Grabbing y Protección WAF	A+	90/100	1 punto(s) de mejora
Configuración de Seguridad del Servidor Web	D	50/100	1 problema(s) crítico(s)
Cifrado y Protección de Comunicaciones (SSL/TLS)	A	85/100	1 punto(s) de mejora
Seguridad del Correo Electrónico y Dominio (DNS)	A+	95/100	1 punto(s) de mejora
Tecnologías, Software y Vulnerabilidades Conocidas	A+	100/100	Sin observaciones relevantes

Seguridad del Contenido y Formularios de la Página	A+	100/100	Sin observaciones relevantes
Archivos y Recursos Expuestos Públicamente	A+	95/100	Sin observaciones relevantes
Secretos y Credenciales Expuestos en JavaScript	—	N/A	Sin observaciones relevantes
Integridad de Scripts Externos (Subresource Integrity)	A+	100/100	Sin observaciones relevantes
Reputación, Listas Negras y Salud de Marca	A+	97/100	Sin observaciones relevantes
Seguridad del Formulario de Autenticación	—	N/A	Sin observaciones relevantes

Comparativa de Estándares de Seguridad

75% de cumplimiento

El sitio **example.com** cumple con el **75%** de las recomendaciones de seguridad evaluadas (12 de 16 controles verificados).

✓	HTTPS habilitado
✗	HSTS configurado
✗	Content-Security-Policy
✗	X-Frame-Options
✗	X-Content-Type-Options
✓	SPF configurado
✓	DMARC configurado
✓	Sin puertos peligrosos
✓	Sin archivos sensibles expuestos
—	Sin secretos en JS (N/A — sin scripts)
✓	TLS moderno (1.2+)
✓	Cookies seguras
✓	Sin versiones expuestas
✓	Sin mixed content
✓	WAF / Protección activa
✓	Scripts externos con SRI
✓	Sin open redirect detectado

Impacto Económico: El Costo de No Actuar

El objetivo de este análisis es transformar un problema técnico en una decisión de negocio. Estos son los costos reales que implica ignorar los problemas de seguridad detectados:

ESCENARIO	COSTO PROMEDIO DE RECUPERACIÓN	COSTO DE PREVENCIÓN
Sitio web hackeado (limpieza de malware, recuperación y rediseño)	Entre \$500 y \$3,000 USD (técnico especializado + días sin operar online)	Menos de \$100 USD/año con seguridad básica configurada
Robo o filtración de datos de clientes	Entre \$1,000 y \$20,000 USD (honorarios legales, notificaciones y daño reputacional)	Configuración correcta de permisos y cifrado — costo cero
Dominio en lista negra (los mails llegan a spam)	Entre \$300 y \$2,000 USD (recuperación de reputación + clientes que no reciben tus mails)	\$0 — se evita configurando SPF y DMARC correctamente
Google marca el sitio como peligroso	Pérdida del 60–90% del tráfico orgánico mientras dura la alerta (semanas o meses)	\$0 — se evita manteniendo el sitio limpio y actualizado
Credenciales o datos expuestos públicamente	Entre \$500 y \$5,000 USD (cambio de sistemas, auditoría y comunicación a clientes)	\$0 — se evita con una configuración correcta del servidor

Conclusión: La inversión en seguridad web básica es, en todos los casos, decenas o cientos de veces menor al costo de recuperarse de un incidente.

Plan de Acción Priorizado — ¿Qué hacer mañana?

Los 5 problemas más urgentes con pasos concretos

A continuación se presentan las acciones más importantes ordenadas por urgencia.

1. URGENTE — Hacer en las próximas 24 horas

Certificado expira pronto (44 días)

Por qué importa: El candado de seguridad venció o está por vencer. Los visitantes verán advertencia de 'sitio no seguro'.

Pasos a seguir:

1. Contactar al proveedor de hosting.
2. Renovar el certificado SSL (Let's Encrypt es gratuito y automático).
3. Verificar que el sitio muestre el candado verde.

2. IMPORTANTE — Hacer esta semana

CDN (Cloudflare) no fuerza HTTPS

Por qué importa: El CDN está activo pero los usuarios que accedan por HTTP no tendrán cifrado.

Pasos a seguir:

1. Ingresar al panel de Cloudflare (o el CDN correspondiente).
2. Ir a SSL/TLS → Edge Certificates.
3. Activar 'Always Use HTTPS'.
4. Verificar que `http://tudominio.com` redirija automáticamente a `https://`.
5. Re-auditar el sitio para confirmar la corrección.

3. IMPORTANTE — Hacer esta semana

Content-Security-Policy ausente

Por qué importa: Cabeceras de seguridad críticas ausentes que protegen contra XSS, MITM y Clickjacking.

Pasos a seguir:

1. Acceder al panel de configuración del servidor web (nginx, Apache, o CDN).
2. Agregar las cabeceras de seguridad faltantes.
3. Verificar con: securityheaders.com
4. Consultar al proveedor de hosting si no tiene acceso directo.
5. Re-auditar el sitio tras los cambios.

4. RECOMENDADO — Próximo mes

Content-Security-Policy ausente

Por qué importa: Sin esta protección el sitio es más vulnerable a ataques de inyección de código (XSS).

Pasos a seguir:

1. Contactar al desarrollador web.
2. Agregar la cabecera Content-Security-Policy.
3. Usar el generador gratuito en: cspisawesome.com

5. RECOMENDADO — Próximo mes**SPF configurado sin mecanismos de envío (bloquea TODO el correo)**

Por qué importa: Las direcciones de email visibles en la web son capturadas por bots de spam.

Pasos a seguir:

1. Reemplazar los emails visibles por un formulario de contacto.
2. Si el email debe mostrarse, usar JavaScript para ofuscarlo.
3. Considerar usar una dirección genérica (contacto@) en lugar de la personal.

Mapeo OWASP Top 10 + Referencias CWE

OWASP es la organización internacional de referencia en seguridad web. CWE (Common Weakness Enumeration) es el diccionario oficial mantenido por MITRE.

HALLAZGO	CATEGORÍA OWASP	CWE	EXPLICACIÓN
Content-Security-Policy ausente	A03:2021 – Injection / XSS	CWE - 693	Sin CSP los ataques de inyección de scripts (XSS) son significativamente más fáciles.
HSTS ausente	A02:2021 – Cryptographic Failures	CWE - 319	HSTS protege contra ataques de degradación de cifrado.
X-Frame-Options ausente	A04:2021 – Insecure Design	CWE - 1021	Sin X-Frame-Options el sitio es vulnerable a Clickjacking.
X-Content-Type-Options ausente	A05:2021 – Security Misconfiguration	CWE - 16	Sin este header el navegador puede ejecutar archivos con MIME type incorrecto (MIME sniffing).
Referrer-Policy ausente	A05:2021 – Security Misconfiguration	CWE - 116	Sin Referrer-Policy las URLs internas se filtran a sitios de terceros en el header Referer.
Permissions-Policy ausente	A05:2021 – Security Misconfiguration	CWE - 284	Sin Permissions-Policy el sitio no controla qué APIs del navegador pueden usar los iframes.
Certificado expira pronto (44 días)	A02:2021 – Cryptographic Failures	CWE - 298	Los problemas con el certificado SSL comprometen la confidencialidad.

Puertos Expuestos, Banner Grabbing y Protección WAF

A+ - 90/100

Estado: Excelente

¿Qué evalúa esta sección?

Los puertos son las 'puertas de entrada' del servidor. Se verifica con timeout anti-tarpitting (1.5s) qué servicios están expuestos. El banner grabbing reutiliza la misma conexión TCP para minimizar el impacto en red.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Puertos abiertos detectados	80/HTTP, 443/HTTPS, 8080/HTTP-Alt, 8443/HTTPS-Alt
Redirección HTTP→HTTPS	■■ CDN activo pero sin forzar HTTPS
Timeout anti-tarpitting	1.5s por puerto

Hallazgos y Recomendaciones

ADVERTENCIA — Se recomienda corregir

CDN (Cloudflare) no fuerza HTTPS
Referencia: [CWE-319](#)
El CDN (Cloudflare) está activo pero no redirige HTTP a HTTPS automáticamente. Los usuarios que accedan por HTTP no serán protegidos por el cifrado.
Recomendación: En el panel de Cloudflare, activar 'Always Use HTTPS' o equivalente.

CORRECTO — Bien configurado

Sin puertos peligrosos expuestos
No se detectaron bases de datos ni servicios de administración expuestos.

Configuración de Seguridad del Servidor Web

D - 50/100

Estado: Deficiente

¿Qué evalúa esta sección?

Las cabeceras HTTP son instrucciones del servidor al navegador sobre cómo comportarse en materia de seguridad. Si hay WAF activo, se ajusta el peso de CSP y X-Frame-Options al 50% ya que el WAF mitiga parcialmente esos vectores.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Content-Security-Policy	■ AUSENTE
HSTS	■ AUSENTE
X-Frame-Options	■ AUSENTE
X-Content-Type-Options	■ AUSENTE
Referrer-Policy	■ AUSENTE
Permissions-Policy	■ AUSENTE
Cross-Origin-Opener-Policy	■ AUSENTE
Cross-Origin-Embedder-Policy	■ AUSENTE
X-XSS-Protection (obsoleto)	■ AUSENTE
Status HTTP	200
Redirect chain	https://example.com/
WAF detectado	✓ Cloudflare
Cache-Control	No configurado

Hallazgos y Recomendaciones

PROBLEMA CRÍTICO — Requiere acción inmediata

HSTS ausente
Referencia: [CWE-319](#)
La cabecera HSTS no está configurada.
Recomendación: Agregar la cabecera 'strict-transport-security' en la configuración del servidor.

ADVERTENCIA — Se recomienda corregir

Content-Security-Policy ausente
Referencia: [CWE-693](#)
La cabecera Content-Security-Policy no está configurada. Nota: el WAF activo (Cloudflare) mitiga parcialmente este riesgo, pero configurar la cabecera sigue siendo una buena práctica.
Recomendación: Agregar la cabecera 'content-security-policy' en la configuración del servidor.

ADVERTENCIA — Se recomienda corregir**X-Frame-Options ausente**

Referencia: [CWE-1021](#)

La cabecera X-Frame-Options no está configurada. Nota: el WAF activo (Cloudflare) mitiga parcialmente este riesgo, pero configurar la cabecera sigue siendo una buena práctica.

Recomendación: Agregar la cabecera 'x-frame-options' en la configuración del servidor.

ADVERTENCIA — Se recomienda corregir**X-Content-Type-Options ausente**

Referencia: [CWE-16](#)

La cabecera X-Content-Type-Options no está configurada.

Recomendación: Agregar la cabecera 'x-content-type-options' en la configuración del servidor.

ADVERTENCIA — Se recomienda corregir**Referrer-Policy ausente**

Referencia: [CWE-116](#)

La cabecera Referrer-Policy no está configurada.

Recomendación: Agregar la cabecera 'referrer-policy' en la configuración del servidor.

ADVERTENCIA — Se recomienda corregir**Permissions-Policy ausente**

Referencia: [CWE-284](#)

La cabecera Permissions-Policy no está configurada.

Recomendación: Agregar la cabecera 'permissions-policy' en la configuración del servidor.

INFORMATIVO**Cross-Origin-Opener-Policy ausente**

La cabecera Cross-Origin-Opener-Policy no está configurada.

Recomendación: Agregar la cabecera 'cross-origin-opener-policy' en la configuración del servidor.

INFORMATIVO**Cross-Origin-Embedder-Policy ausente**

La cabecera Cross-Origin-Embedder-Policy no está configurada.

Recomendación: Agregar la cabecera 'cross-origin-embedder-policy' en la configuración del servidor.

INFORMATIVO**X-XSS-Protection (obsoleto) ausente**

La cabecera X-XSS-Protection (obsoleto) no está configurada.

Recomendación: No es necesario configurarla. Está deprecada en navegadores modernos y puede introducir vulnerabilidades XSS en lugar de prevenirlas.

INFORMATIVO**Cabecera 'server' expuesta (valor controlado por CDN)**

Valor: 'cloudflare' — este valor lo establece el CDN/proxy automáticamente y no puede ser modificado por el administrador.

Recomendación: No requiere acción. Es un comportamiento normal del CDN.

INFORMATIVO

Cache-Control no configurado

Sin Cache-Control el navegador y proxies pueden cachear respuestas con datos sensibles.

Recomendación: Configurar Cache-Control: no-store en páginas autenticadas o con datos personales.

CORRECTO — Bien configurado

WAF detectado: Cloudflare

Se detectó un firewall de aplicaciones web (Cloudflare) protegiendo el sitio. Nota: Este sitio está protegido por Cloudflare WAF. Algunas pruebas se ajustaron para evitar bloqueos — los resultados reflejan lo visible públicamente.

Cifrado y Protección de Comunicaciones (SSL/TLS)

A - 85/100

Estado: Muy buena

¿Qué evalúa esta sección?

Se verifica el protocolo TLS negociado, si el servidor acepta TLS 1.0/1.1 obsoletos, la calidad de la cipher suite, la validez del certificado y su algoritmo de firma.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Protocolo TLS (negociado)	TLSv1.3
TLS 1.0 aceptado	✓ Rechazado
TLS 1.1 aceptado	✓ Rechazado
Cipher suite activa	TLS_AES_256_GCM_SHA384 (256 bits)
Emisor	CN=Cloudflare TLS Issuing ECC CA 1,O=CLOUDFLARE\, INC.,C=US
Expira	2026-07-01 (44 días)
Válido desde	2026-04-02
SAN (dominios cubiertos)	example.com, *.example.com
Algoritmo de firma	SHA256
HTTP/2	✓ Soportado por Cloudflare

Hallazgos y Recomendaciones

ADVERTENCIA — Se recomienda corregir

Certificado expira pronto (44 días)
Referencia: [CWE-298](#)
Menos de 60 días de validez. Se recomienda renovar con anticipación.
Recomendación: [Renovar el certificado antes de que expire.](#)

CORRECTO — Bien configurado

Protocolo seguro negociado: TLSv1.3
TLS 1.2+ está en uso.

CORRECTO — Bien configurado

Cifrado fuerte: 256 bits
Suite: TLS_AES_256_GCM_SHA384

CORRECTO — Bien configurado

Certificado SSL presente
El sitio tiene SSL configurado.

CORRECTO — Bien configurado

HTTP/2 soportado vía CDN (Cloudflare)

Cloudflare provee HTTP/2 automáticamente. No se detectó el header Alt-Svc pero el protocolo está activo.

Seguridad del Correo Electrónico y Dominio (DNS)

A+ - 95/100

Estado: Excelente

¿Qué evalúa esta sección?

Protege el dominio de suplantación por email (SPF, DKIM, DMARC), verifica DNSSEC y detecta subdominios via Certificate Transparency (crt.sh, timeout 3s).

Datos relevantes

PARÁMETRO	VALOR DETECTADO
SPF	v=spf1 -all
DMARC	v=DMARC1;p=reject;sp=reject;adkim=s;aspf=s
DKIM	✓ Selector 'default' encontrado
DNSSEC	✓ Habilitado
CAA	No configurado
MX	Sin servidores de email
IPs del servidor	104.20.23.154, 172.66.147.243
Subdominios (RapidDNS) — 2 total	20mail2.example.com, www.example.com

Hallazgos y Recomendaciones

ADVERTENCIA — Se recomienda corregir

SPF configurado sin mecanismos de envío (bloquea TODO el correo)

Referencia: CWE-345

El registro SPF es 'v=spf1 -all' y no autoriza ningún servidor (sin include:, ip4:, ip6:, a:, mx:). Esto bloquea cualquier email saliente del dominio, incluido el correo legítimo.

Recomendación: Agregar los servidores de correo autorizados. Ej: 'v=spf1 include:_spf.google.com ~all' para Google Workspace.

INFORMATIVO

Sin registro CAA

Cualquier CA puede emitir certificados para este dominio.

Recomendación: Agregar registro CAA para limitar qué CAs pueden emitir certificados.

INFORMATIVO

2 subdominios detectados vía RapidDNS

Encontrados: 20mail2.example.com, www.example.com

Recomendación: Revisar que todos los subdominios expuestos sean intencionales y estén correctamente asegurados.

CORRECTO — Bien configurado

SPF configurado

v=spf1 -all

CORRECTO — Bien configurado

DMARC configurado

v=DMARC1;p=reject;sp=reject;adkim=s;aspf=s

CORRECTO — Bien configurado

DKIM configurado (selector: default)

Las firmas digitales de email están habilitadas.

CORRECTO — Bien configurado

DNSSEC habilitado

Las respuestas DNS están firmadas digitalmente.

Tecnologías, Software y Vulnerabilidades Conocidas

A+ - 100/100

Estado: Excelente

¿Qué evalúa esta sección?

Identifica el stack tecnológico por cabeceras, HTML y favicon. El Deep Scan de CMS se ejecuta al final con el set completo de tecnologías detectadas. Verifica CVEs conocidos usando lookup directo en diccionario plano.

Tecnologías identificadas

Cloudflare · Cloudflare CDN

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Tecnologías detectadas	Cloudflare, Cloudflare CDN
Versiones expuestas	Ninguna detectada
Server header	cloudflare
X-Powered-By	Oculto (buena práctica)

Hallazgos y Recomendaciones

INFORMATIVO

2 tecnologías identificadas
Stack detectado: Cloudflare, Cloudflare CDN
Recomendación: Verificar que todas las tecnologías estén en sus últimas versiones.

Seguridad del Contenido y Formularios de la Página

A+ - 100/100

Estado: Excelente

¿Qué evalúa esta sección?

Analiza el código fuente de la página: formularios sin protección CSRF, métodos GET en formularios sensibles, emails expuestos, mixed content y comentarios sensibles.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Mixed content	✓ Ninguno
Formularios detectados	0 total, 0 con action HTTP inseguro
Emails expuestos en HTML	✓ Ninguno detectado
Campos password	0 detectado(s)
Comentarios sospechosos	✓ Ninguno
iframes	0
Open Redirect (pasivo)	✓ Sin parámetros de redirección externos detectados

Hallazgos y Recomendaciones

CORRECTO — Bien configurado

Sin mixed content detectado
Todos los recursos parecen cargarse por HTTPS.

Archivos y Recursos Expuestos Públicamente

A+ - 95/100

Estado: Excelente

¿Qué evalúa esta sección?

Verifica 38+ rutas conocidas en paralelo (ThreadPoolExecutor, 10 workers) reduciendo el tiempo de ~15s a ~2-3s. Cualquier acceso positivo a archivos críticos es un hallazgo urgente.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
robots.txt	No disponible (404)
sitemap.xml	No disponible (404)
security.txt (RFC 9116)	No disponible (404)
security.txt (raíz)	No disponible (404)
OpenID Configuration (info disclosure)	No disponible (404)
OAuth Server Metadata (info disclosure)	No disponible (404)
Apple App Site Association	No disponible (404)
Android Asset Links	No disponible (404)
MTA-STS Policy (email)	No disponible (404)
crossdomain.xml	No disponible (404)
clientaccesspolicy.xml	No disponible (404)
.git/HEAD ■■■ PELIGROSO	No disponible (404)
.git/config ■■■ PELIGROSO	No disponible (404)
.svn/entries ■■■ PELIGROSO	No disponible (404)
.hg/hgrc ■■■ PELIGROSO	No disponible (404)
.env ■■■ MUY PELIGROSO	No disponible (404)
.env.local ■■■ PELIGROSO	No disponible (404)
.env.production ■■■ PELIGROSO	No disponible (404)
.env.backup ■■■ PELIGROSO	No disponible (404)
config.php	No disponible (404)
wp-config.php.bak ■■■ PELIGROSO	No disponible (404)
.vscode/settings.json ■■■	No disponible (404)
.idea/workspace.xml ■■■	No disponible (404)
docker-compose.yml ■■■ PELIGROSO	No disponible (404)
docker-compose.yaml ■■■ PELIGROSO	No disponible (404)
Dockerfile ■■■	No disponible (404)
package.json ■■■	No disponible (404)

composer.json ■■	No disponible (404)
requirements.txt ■■	No disponible (404)
backup.zip ■■ PELIGROSO	No disponible (404)
backup.sql ■■ PELIGROSO	No disponible (404)
dump.sql ■■ PELIGROSO	No disponible (404)
database.sql ■■ PELIGROSO	No disponible (404)
db.sql ■■ PELIGROSO	No disponible (404)
.DS_Store ■■	No disponible (404)
phpinfo.php ■■ PELIGROSO	No disponible (404)
.htaccess	No disponible (404)
wp-login.php	No disponible (404)
/admin	No disponible (404)
Apache server-status	No disponible (404)
error.log ■■	No disponible (404)
debug.log ■■	No disponible (404)

Hallazgos y Recomendaciones

INFORMATIVO

security.txt ausente

No hay política de divulgación responsable de vulnerabilidades (RFC 9116).

Recomendación: Crear /.well-known/security.txt con contacto y política.

Secretos y Credenciales Expuestos en JavaScript

Estado: No evaluable

¿Qué evalúa esta sección?

Descarga y analiza archivos JavaScript propios del sitio con 12+ patrones para detectar credenciales expuestas. Solo marca 'Sin secretos' si efectivamente se escanearon scripts.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Scripts JS propios detectados	0
Scripts JS analizados	0
Secretos detectados	✓ Ninguno

Integridad de Scripts Externos (Subresource Integrity)

A+ - 100/100

Estado: Excelente

¿Qué evalúa esta sección?

Verifica si los scripts cargados desde CDN externos tienen el atributo 'integrity' (Subresource Integrity). Sin SRI, si el CDN es comprometido, el atacante puede inyectar código malicioso que se ejecuta en todos los visitantes del sitio.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Scripts externos detectados	0
Scripts con SRI	0
Scripts sin SRI	✓ 0

Hallazgos y Recomendaciones

CORRECTO — Bien configurado

Sin scripts externos detectados

No se encontraron scripts de CDN externos.

Reputación, Listas Negras y Salud de Marca

A+ - 97/100

Estado: Excelente

¿Qué evalúa esta sección?

Verifica si el dominio o su IP aparece en listas negras DNSBL (Spamhaus, SpamCop, SORBS), consulta URLScan.io y verifica antigüedad del dominio vía RDAP.

PARÁMETRO	VALOR DETECTADO
URLScan.io	10000 escaneos previos
IP del sitio	104.20.23.154
Blacklists DNSBL	✓ No listado
Registro dominio	1995-08-14T04:00:00Z
Expiración dominio	2026-08-13T04:00:00Z
Días hasta expiración dominio	87 días
Antigüedad del dominio	11234 días (30 años)
HSTS Preload status	unknown

Hallazgos y Recomendaciones

INFORMATIVO

Dominio expira en 87 días
El dominio vence en menos de 3 meses. Recordar renovarlo.
Recomendación: Activar la renovación automática en el registrar.

INFORMATIVO

Dominio NO está en la lista HSTS Preload (estado: unknown)
El HSTS Preload list hace que los navegadores fuercen HTTPS incluso antes de la primera visita, protegiéndola del primer request sin cifrar.
Recomendación: Si el sitio tiene HSTS configurado correctamente, solicitar inclusión en: hstspreload.org

INFORMATIVO

Verificación adicional recomendada
Para análisis completo de reputación: Google Safe Browsing, VirusTotal y Shodan.
Recomendación: Crear cuentas gratuitas en: [virustotal.com](https://www.virustotal.com), [shodan.io](https://www.shodan.io)

CORRECTO — Bien configurado

URLScan.io: sin amenazas (10000 escaneos)
Último escaneo: 2026-05-17T22:12:26.989Z

CORRECTO — Bien configurado

Sin entradas en listas negras DNSBL verificadas
La IP 104.20.23.154 no aparece en las listas negras principales verificadas.

CORRECTO — Bien configurado

Dominio establecido (30 años)

Seguridad del Formulario de Autenticación

Estado: No evaluable

¿Qué evalúa esta sección?

Detecta la página de login en rutas comunes y analiza: protección CSRF, autocomplete en campos de contraseña, rate limiting visible, presencia de captcha y mensajes de error que puedan revelar si un usuario existe.

Datos relevantes

PARÁMETRO	VALOR DETECTADO
Página de login	No detectada en rutas comunes

Hallazgos y Recomendaciones

INFORMATIVO

No se detectó página de login en rutas comunes

No se encontró formulario de login en las rutas estándar. Puede existir en una ruta personalizada.

Marco Legal y Alcance del Análisis

1. Alcance del Análisis

Este análisis es estrictamente pasivo y limitado a información expuesta públicamente en internet. No se realizaron intentos de acceso no autorizado, inyecciones, exploits ni ninguna técnica activa.

2. Exención de Responsabilidad

Este informe representa una 'fotografía' del estado de seguridad del sitio en el momento específico del análisis. La seguridad informática es un campo dinámico. Se recomienda realizar auditorías periódicas (mínimo cada 6 meses).

3. Uso Ético y Autorización

Al solicitar este análisis, el cliente declara ser el propietario legítimo del sitio o contar con autorización expresa del propietario para realizar esta evaluación. Este documento es confidencial y está destinado exclusivamente al cliente que encargó el análisis.

4. Limitaciones Técnicas

Este análisis pasivo no puede detectar vulnerabilidades en el código fuente interno, configuraciones no visibles públicamente, accesos no autorizados previos sin rastros visibles, ni vulnerabilidades en sistemas de terceros o integraciones privadas.

Glosario de Términos Técnicos

SSL / TLS	Protocolos de cifrado del tráfico web. Se identifican por 'https://' y el candado en el navegador.
Banner Grabbing	Lectura pasiva de la primera respuesta de un servicio para identificar software y versión (en una sola conexión TCP).
SRI	Subresource Integrity. Atributo integrity= en scripts externos que verifica que el archivo no fue modificado en el CDN.
Open Redirect	Vulnerabilidad donde un parámetro de URL puede redirigir al usuario a un sitio externo malicioso usando el dominio confiable.
Apex domain	Dominio raíz sin subdominio. Ej: amazon.com es el apex de www.amazon.com. Los registros SPF/DMARC viven en el apex.
CWE-829	Inclusión de funcionalidad de esfera de control no confiable. Aplica a scripts externos sin verificación de integridad.
CWE-601	Redirección de URL a sitio no confiable (Open Redirect).
CVE	Common Vulnerabilities and Exposures. Identificador oficial de vulnerabilidades de seguridad conocidas públicamente.
CWE	Common Weakness Enumeration. Diccionario oficial de debilidades de software mantenido por MITRE.
OWASP Top 10	Lista de los 10 riesgos más críticos en aplicaciones web, reconocida mundialmente.
CSRF	Cross-Site Request Forgery. Ataque que engaña al usuario para que ejecute acciones no deseadas.
Jitter (Matriz)	Pequeño desplazamiento aplicado a puntos con las mismas coordenadas para que sean visibles individualmente.
SPF / DKIM / DMARC	Estándares de seguridad del email que evitan que terceros suplanten el dominio.
DNSSEC	Extensión que firma las respuestas DNS para evitar redirecciones maliciosas.
WAF	Web Application Firewall. Escudo que bloquea ataques antes de que lleguen al sitio. Ajusta el peso de algunas cabeceras.
CT Logs / crt.sh	Certificate Transparency. Base de datos pública de certificados SSL usada para descubrir subdominios. Se consultan 3 fuentes en paralelo: crt.sh, HackerTarget y RapidDNS.
DNSBL	DNS Blacklist. Listas de IPs y dominios conocidos como fuentes de spam o malware, consultadas vía DNS.
Tarpitting	Técnica de firewall que mantiene conexiones abiertas indefinidamente. El timeout de 1.5s previene bloqueos.
Deep Scan CMS	Verificación de rutas específicas de cada CMS ejecutada con el set completo de tecnologías ya detectadas.

Análisis pasivo

Auditoría que solo consulta información pública, sin intentar acceder a zonas restringidas.

Informe generado de forma automatizada mediante análisis pasivo y no invasivo — Web Security Auditor v5.0. Documento confidencial destinado exclusivamente al cliente solicitante.